



CODE ALPHA

CYBER SECURITY INTERSHIP

TASK 03: SECURE CODING REVIEW

Intern Name: Ayan Shahid

Organization: CodeAlpha

Email: ayanshahid0295@gmail.com

Submitted Date: 17-Jan-2026

TASK 03 REPORT

1. Introduction:

Secure coding review is the process of examining an application's source code to identify security weaknesses that could be exploited by attackers. In this task, a manual secure code review was conducted on an open-source web application to identify vulnerabilities and recommend secure coding practices to improve overall application security.

2. Selected Programming Language and Application:

- **Programming Language:** PHP
- **Application:** ReciPHP
- **Application Type:** Open-source web-based recipe management system
- **Database:** MySQL

ReciPHP was selected because it is an open-source PHP application and contains common web security vulnerabilities.

3. Methodology Used for Code Review:

The secure coding review was performed using the following methods:

1. Manual Code Inspection:

Source files were manually reviewed to identify insecure coding practices.

2. Static Analysis Using findstr:

The findstr command was used to search for insecure functions and patterns commonly associated with vulnerabilities such as SQL Injection, XSS, and file inclusion.

4. Identified Security Vulnerabilities:

• SQL Injection (SQLi):

Several PHP files directly used user input in SQL queries without validation or parameterization. The risk is attackers can manipulate SQL queries to access or modify database data. The affected files are following and the vulnerable code is highlighted:

➤ addrecipe.inc.php:

```
11 if (trim($poster == ''))
12 {
13     echo "<h2>Sorry, each recipe must have a poster</h2>\n";
14 }else
15 {
16     $query = "INSERT INTO recipes (title, shortdesc, poster, ingredients, directions) " .
17         " VALUES ('$title', '$shortdesc', '$poster', '$ingredients', '$directions')";
18     $result = mysql_query($query) or die('Sorry, we could not post your recipe to the database at this time');
19 }
20 if ($result)
21 {
22     echo "<h2>Recipe posted</h2>\n";
23 }else
24 {
25     echo "<h2>Sorry, there was a problem posting your recipe</h2>\n";
26 }
27 ?>
```

➤ **addcomment.inc.php:**

```
addcomment.inc.php X
addcomment.inc.php
1  <?php include 'config.php'; ?>
2  <div id="main">
3  <div id='preview'>
4  <?php
5  $recipeid = $_POST['recipeid'];
6  $poster = $_POST['poster'];
7  $comment = htmlspecialchars($_POST['comment']);
8  $date = date("Y-m-d");
9
10
11
12  $query = "INSERT INTO comments (recipeid, poster, date, comment) " .
13  | | | " VALUES ($recipeid, '$poster', '$date', '$comment')";
14
15  $result = mysql_query($query);
16  if ($result)
17  |   echo "<h2>Comment posted</h2>\n";
18  else
19  |   echo "<h2>Sorry, there was a problem posting your comment</h2>\n";
20
21  echo "<a href=\"index.php?content=showrecipe&id=$recipeid\">Return to recipe</a>\n";
22  ?>
23 </div>
24 </div>
```

➤ **search.inc.php:**

```
addrecipe.inc.php X search.inc.php X
search.inc.php
4  ?php
5
6
7  $search = $_GET['searchFor'];
8  $query = "SELECT recipeid,title,shortdesc from recipes where title like '%$search%'";
9
10 $result = mysql_query($query) or die('Could not query database at this time');
11
12 echo "<h1>Search Results</h1><br><br>\n";
13
14 if (mysql_num_rows($result) == 0)
15 {
16 |   echo "<h2>Sorry, no recipes were found with '$search' in them.</h2>";
17 } else
18 {
19 |   echo "<h2>Recipes matching '$search':</h2><br><br>";
20 |   while($row=mysql_fetch_array($result, MYSQL_ASSOC))
21 |   {
22 |       $recipeid = $row['recipeid'];
23 |       $title = $row['title'];
24 |       $shortdesc = $row['shortdesc'];
25 |       echo "<a href=\"index.php?content=showrecipe&id=$recipeid\">$title</a><br>\n";
26 |       echo "$shortdesc<br><br>\n";
27 |   }
28 }
29 >
```

➤ print.php:

```
addrecipe.inc.php  print.php X
print.php
2 <html xmlns="http://www.w3.org/1999/xhtml">
3 <head>
4 <link rel="stylesheet" type="text/css" href="print.css" />
5 <title>The Recipe Center</title>
6 </head>
7
8 <body>
9 <?php include 'config.php'; ?>
10 <?php
11
12
13
14 $recipeid = $_GET['id'];
15
16 $query = "SELECT title,poster,shortdesc,ingredients,directions from recipes where recipeid
17 $result = mysql_query($query) or die('Could not find recipe');
18 $row = mysql_fetch_array($result, MYSQL_ASSOC) or die('No records retrieved');
19
20 $title = $row['title'];
21 $poster = $row['poster'];
22 $shortdesc = $row['shortdesc'];
23 $ingredients = $row['ingredients'];
24 $directions = $row['directions'];
25
```

➤ validate.inc.php:

```
addrecipe.inc.php  validate.inc.php X
validate.inc.php
1 <?php include 'config.php'; ?>
2 <div id="main">
3 <div id='preview'><?php
4
5
6 $userid = $_POST['userid'];
7 $password = $_POST['password'];
8
9 $query = "SELECT userid from users where userid = '$userid' and password = PASSWORD('$password')";
10 $result = mysql_query($query);
11
12 if (mysql_num_rows($result) == 0)
13 {
14     echo "<h2>Sorry, your user account was not validated.</h2><br>\n";
15     echo "<a href='\"index.php?content=login\"'>Try again</a><br>\n";
16     echo "<a href='\"index.php\"'>Return to Home</a>\n";
17 } else
18 {
19     $_SESSION['valid_recipe_user'] = $userid;
20     echo "<h2>Your user account has been validated, you can now post recipes and comments</h2><br>\n";
21     echo "<a href='\"index.php\"'>Return to Home</a>\n";
22 }
23 ?>
24 </div></div>
```

➤ showrecipe.inc.php:

```
addrecipe.inc.php  showrecipe.inc.php X
showrecipe.inc.php
5
6  $recipeid = $_GET['id'];
7
8  $query = "SELECT title,poster,shortdesc,ingredients,directions from recipes where recipeid
9
10 $result = mysql_query($query) or die('Could not find recipe');
11 $row = mysql_fetch_array($result, MYSQL_ASSOC) or die('No records retrieved');
12 $title = $row['title'];
13 $poster = $row['poster'];
14 $shortdesc = $row['shortdesc'];
15 $ingredients = $row['ingredients'];
16 $directions = $row['directions'];
17
18 $ingredients = nl2br($ingredients);
19 $directions = nl2br($directions);
20
21 echo "<h2>$title</h2>\n";
22
23 echo "by $poster <br><br>\n";
24 echo $shortdesc . "<br><br>\n";
25 echo "<h3>Ingredients:</h3>\n";
26 echo $ingredients . "<br><br>\n";
27
28 echo "<h3>Directions:</h3>\n";
29 echo $directions . "\n";
30 echo "<br><br>\n";
31
32 $query = "SELECT count(commentid) from comments where recipeid = $recipeid";
33 $result = mysql_query($query);
34 $row=mysql_fetch_array($result);
35
36 $row=mysql_fetch_array($result);
37 if ($row[0] == 0)
38 {
39     echo "No comments posted yet.&nbsp;&nbsp;&nbsp;\n";
40     echo "<a href='\"index.php?content=newcomment&id=$recipeid\"'>Add a comment</a>\n";
41     echo "&nbsp;&nbsp;&nbsp;<a href='\"print.php?id=$recipeid\"' target='\"_blank\"'>Print recipe</a>\n";
42     echo "<hr>\n";
43 } else
44 {
45     $totrecords = $row[0];
46     echo $row[0] . "\n";
47     echo "&nbsp;&nbsp;&nbsp;comments posted.&nbsp;&nbsp;&nbsp;\n";
48     echo "<a href='\"index.php?content=newcomment&id=$recipeid\"'>Add a comment</a>\n";
49     echo "&nbsp;&nbsp;&nbsp;<a href='\"print.php?id=$recipeid\"' target='\"_blank\"'>Print recipe</a>\n";
50     echo "<hr>\n";
51     echo "<h2>Comments:</h2>\n";
52
53 {
54     $offset = ($thispage - 1) * $recordsperpage;
55     $totpages = ceil($totrecords / $recordsperpage);
56
57     $query = "SELECT date,poster,comment from comments where recipeid = $recipeid order by commentid desc limit $offset,$
58     $result = mysql_query($query) or die('Could not retrieve comments');
59     while($row = mysql_fetch_array($result, MYSQL_ASSOC))
60     {
61         $date = $row['date'];
62         $poster = $row['poster'];
63         $comment = $row['comment'];
64         $comment = nl2br($comment);
65     }
66 }
```

```

98     }
99
100    if ($thispage < $totpages)
101    {
102        $page = $thispage + 1;
103        $nextpage = " <a href=\"index.php?content=showrecipe&id=$recipeid&page=$page\">Next</a>";
104    } else
105    {
106        $nextpage = "Next";
107    }
108
109    echo "GoTo: " . $prevpage . $bar . $nextpage;
110 }
111 ?></div>

```

- **Cross-Site Scripting (XSS):**

User input was displayed on web pages without sanitization. The risk includes attackers can inject malicious JavaScript to steal user sessions or perform malicious actions. The affected files are following and the vulnerable code is highlighted:

➤ **addcomment.inc.php:**

```

addcomment.inc.php X
addcomment.inc.php
1  <?php include 'config.php'; ?>
2  <div id="main">
3  <div id='preview'>
4  <?php
5  $recipeid = $_POST['recipeid'];
6  $poster = $_POST['poster'];
7  $comment = htmlspecialchars($_POST['comment']);
8  $date = date("Y-m-d");
9
10
11
12  $query = "INSERT INTO comments (recipeid, poster, date, comment) " .
13  | | | " VALUES ($recipeid, '$poster', '$date', '$comment')";
14
15  $result = mysql_query($query);
16  if ($result)
17  echo "<h2>Comment posted</h2>\n";
18  else
19  echo "<h2>Sorry, there was a problem posting your comment</h2>\n";
20
21  echo "<a href=\"index.php?content=showrecipe&id=$recipeid\">Return to recipe</a>\n";
22  ?>
23  </div>
24  </div>

```


➤ search.inc.php:

```
addrecipe.inc.php × search.inc.php ×
search.inc.php
4  ?php
5
6
7  $search = $_GET['searchFor'];
8  $query = "SELECT recipeid,title,shortdesc from recipes where title like '%$search%'";
9
10 $result = mysql_query($query) or die('Could not query database at this time');
11
12 echo "<h1>Search Results</h1><br><br>\n";
13
14 if (mysql_num_rows($result) == 0)
15 {
16     echo "<h2>Sorry, no recipes were found with '$search' in them.</h2>";
17 } else
18 {
19     echo "<h2>Recipes matching '$search':</h2><br><br>";
20     while($row=mysql_fetch_array($result, MYSQL_ASSOC))
21     {
22         $recipeid = $row['recipeid'];
23         $title = $row['title'];
24         $shortdesc = $row['shortdesc'];
25         echo "<a href='\"index.php?content=showrecipe&id=$recipeid\"'>$title</a><br>\n";
26         echo "$shortdesc<br><br>\n";
27     }
28 }
29 >
```

➤ showrecipe.inc.php:

```
addrecipe.inc.php showrecipe.inc.php ×
showrecipe.inc.php
5
6  $recipeid = $_GET['id'];
7
8  $query = "SELECT title,poster,shortdesc,ingredients,directions from recipes where recipeid
9
10 $result = mysql_query($query) or die('Could not find recipe');
11 $row = mysql_fetch_array($result, MYSQL_ASSOC) or die('No records retrieved');
12 $title = $row['title'];
13 $poster = $row['poster'];
14 $shortdesc = $row['shortdesc'];
15 $ingredients = $row['ingredients'];
16 $directions = $row['directions'];
17
18 $ingredients = nl2br($ingredients);
19 $directions = nl2br($directions);
20
21 echo "<h2>$title</h2>\n";
22
23 echo "by $poster <br><br>\n";
24 echo $shortdesc . "<br><br>\n";
25 echo "<h3>Ingredients:</h3>\n";
26 echo $ingredients . "<br><br>\n";
27
28 echo "<h3>Directions:</h3>\n";
29 echo $directions . "\n";
30 echo "<br><br>\n";
31
32 $query = "SELECT count(commentid) from comments where recipeid = $recipeid";
33 $result = mysql_query($query);
34 $row=mysql_fetch_array($result);
```

```
addrecipe.inc.php showrecipe.inc.php X
showrecipe.inc.php
34 $row=mysql_fetch_array($result);
35 if ($row[0] == 0)
36 {
37     echo "No comments posted yet.&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&";
38     echo "<a href='index.php?content=newcomment&id=$recipeid'>Add a comment</a>\n";
39     echo "&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&<a href='print.php?id=$recipeid' target='_blank'>Print recipe</a>\n";
40     echo "<hr>\n";
41 } else
42 {
43     $totrecords = $row[0];
44     echo $row[0] . "\n";
45     echo "&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&comments posted.&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&";
46     echo "<a href='index.php?content=newcomment&id=$recipeid'>Add a comment</a>\n";
47     echo "&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&<a href='print.php?id=$recipeid' target='_blank'>Print recipe</a>\n";
48     echo "<hr>\n";
49     echo "<h2>Comments:</h2>\n";
50 }
51 }
52 {
53     $offset = ($thispage - 1) * $recordsperpage;
54     $totpages = ceil($totrecords / $recordsperpage);
55     $query = "SELECT date,poster,comment from comments where recipeid = $recipeid order by commentid desc limit $offset, $recordsperpage";
56     $result = mysql_query($query) or die('Could not retrieve comments');
57     while($row = mysql_fetch_array($result, MYSQL_ASSOC))
58     {
59         $date = $row['date'];
60         $poster = $row['poster'];
61         $comment = $row['comment'];
62         $comment = nl2br($comment);
63     }
64 }
65 }
66 }
67 }
68 }
69 }
70 }
71 }
72 }
73 }
74 }
75 }
76 }
77 }
78 }
79 }
80 }
81 }
82 }
83 }
84 }
85 }
86 }
87 }
88 }
89 }
90 }
91 }
92 }
93 }
94 }
95 }
96 }
97 }
98 }
99 }
100 }
101 }
102 }
103 }
104 }
105 }
106 }
107 }
108 }
109 }
110 }
111 }
112 }
113 }
114 }
115 }
116 }
117 }
118 }
119 }
120 }
121 }
122 }
123 }
124 }
125 }
126 }
127 }
128 }
129 }
130 }
131 }
132 }
133 }
134 }
135 }
136 }
137 }
138 }
139 }
140 }
141 }
142 }
143 }
144 }
145 }
146 }
147 }
148 }
149 }
150 }
151 }
152 }
153 }
154 }
155 }
156 }
157 }
158 }
159 }
160 }
161 }
162 }
163 }
164 }
165 }
166 }
167 }
168 }
169 }
170 }
171 }
172 }
173 }
174 }
175 }
176 }
177 }
178 }
179 }
180 }
181 }
182 }
183 }
184 }
185 }
186 }
187 }
188 }
189 }
190 }
191 }
192 }
193 }
194 }
195 }
196 }
197 }
198 }
199 }
200 }
```

➤ newcomment.inc.php:

```
addrecipe.inc.php newcomment.inc.php X
newcomment.inc.php
1 <div id="main">
2 <div id='preview'>
3 <?php
4 $recipeid = $_GET['id'];
5 if (!isset($_SESSION['valid_recipe_user']))
6 {
7     echo "<h2>Sorry, you do not have permission to post comments</h2><br>\n";
8     echo "<a href='index.php?content=login'>Please login to post comments</a><br>\n";
9     echo "<a href='index.php?content=showrecipe&id=$recipeid'>Go back to recipe</a>\n";
10 } else
11 {
12     $userid = $_SESSION['valid_recipe_user'];
13     echo "<form action='index.php' method='post'>\n";
14     echo "<h2>Enter your comment</h2>";
15     echo "<textarea rows='10' cols='50' name='comment'></textarea><br>\n";
16 }
```


➤ **newcomment.inc.nologin.php:**

```
addrecipe.inc.php  newcomment.inc.nologin.php X
newcomment.inc.nologin.php
1  <?php
2  $recipeid = $_GET['id'];
3  echo "<form action=\"index.php\" method=\"post\">\n";
4  echo "<h2>Enter your comment</h2>";
5  echo "<textarea rows=\"10\" cols=\"50\" name=\"comment\"></textarea><br>\n";
6
7  echo "Submitted by:<input type=\"text\" name=\"poster\"><br>\n";
8  echo "<input type=\"hidden\" name=\"recipeid\" value=\"$recipeid\">\n";
9  echo "<input type=\"hidden\" name=\"content\" value=\"addcomment\">\n";
10 echo "<br><input type=\"submit\" value=\"Submit\">\n";
11 echo "</form>\n";
12 ?>
```

- **Hard-Coded Credentials:**

Database credentials were stored directly in the source code. The risk includes if source code is exposed, attackers can gain database access. The affected files are following and the vulnerable code is highlighted:

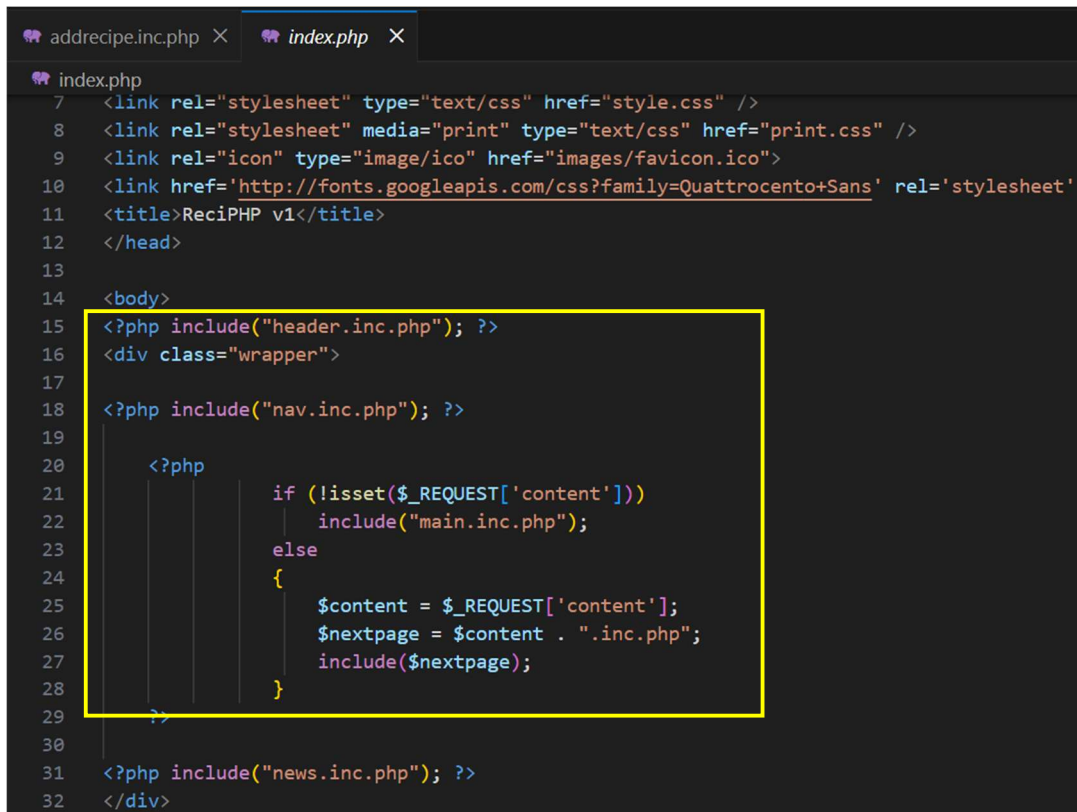
➤ **config.php:**

```
config.php X
config.php
1  <?php
2  $host = "localhost"; //database location
3  $user = "root"; //database username
4  $pass = "12345"; //database password
5  $db_name = "reciphp"; //database name
6
7  //database connection
8  $link = mysql_connect($host, $user, $pass);
9  mysql_select_db($db_name);
10
11 //sets encoding to utf8
12 mysql_query("SET NAMES utf8");
13 ?>
```

- **File Inclusion Vulnerability:**

User-controlled input was used in file inclusion statements. The risk includes it allows local or remote file inclusion attacks. The affected files are following and the vulnerable code is highlighted:

➤ index.php:



```
index.php
7 <link rel="stylesheet" type="text/css" href="style.css" />
8 <link rel="stylesheet" media="print" type="text/css" href="print.css" />
9 <link rel="icon" type="image/ico" href="images/favicon.ico">
10 <link href="http://fonts.googleapis.com/css?family=Quattrocento+Sans" rel="stylesheet" />
11 <title>ReciPHP v1</title>
12 </head>
13
14 <body>
15 <?php include("header.inc.php"); ?>
16 <div class="wrapper">
17
18 <?php include("nav.inc.php"); ?>
19
20 <?php
21     if (!isset($_REQUEST['content']))
22         include("main.inc.php");
23     else
24     {
25         $content = $_REQUEST['content'];
26         $nextpage = $content . ".inc.php";
27         include($nextpage);
28     }
29 ?>
30
31 <?php include("news.inc.php"); ?>
32 </div>
```

5. Tools Used:

- Manual Code Review
- findstr (Static Inspection Tool)
- XAMPP environment

6. Static Code Analysis (Using findstr):

The findstr is used in static code analysis to search source files for specific insecure coding patterns without executing the application.

➤ SQL Injection:

```
PS C:\Users\Ayan Shahid> cd C:\xampp\htdocs\reciphp
PS C:\xampp\htdocs\reciphp> findstr /S /I "mysql_query" *.php
addcomment.inc.php:$result = mysql_query($query);
addrecipe.inc.php:$result = mysql_query($query) or die('Sorry, we could not post your recipe to the database at this time');
adduser.inc.php:$result = mysql_query($query);
adduser.inc.php:$result = mysql_query($query) or die('Sorry, we are unable to process your request. ');
config.php:mysql_query("SET NAMES utf8");
main.inc.php:$result = mysql_query($query) or die('Could not get recipies: ' . mysql_error());
news.inc.php:$result = mysql_query($query) or die('Sorry, could not get news articles');
print.php:$result = mysql_query($query) or die('Could not find recipe');
search.inc.php:$result = mysql_query($query) or die('Could not query database at this time');
showrecipe.inc.nopaging.php:$result = mysql_query($query) or die('Could not find recipe: ' . mysql_error());
showrecipe.inc.nopaging.php:$result = mysql_query($query);
showrecipe.inc.nopaging.php:$result = mysql_query($query) or die('Could not retrieve comments');
showrecipe.inc.php:$result = mysql_query($query) or die('Could not find recipe');
showrecipe.inc.php:$result = mysql_query($query);
showrecipe.inc.php:$result = mysql_query($query) or die('Could not retrieve comments');
validate.inc.php:$result = mysql_query($query);
PS C:\xampp\htdocs\reciphp>
```

➤ Cross-Site Scripting (XSS):

```
PS C:\xampp\htdocs\reciphp> findstr /S /I "echo $" *.php
addcomment.inc.php: echo "<h2>Comment posted</h2>\n";
addcomment.inc.php: echo "<h2>Sorry, there was a problem posting your comment</h2>\n";
addcomment.inc.php:echo "<a href=\"index.php?content=showrecipe&id=$recipeid\">Return to recipe</a>\n";
addcomment_FIXED.inc.php: echo "<a href=\"index.php?content=login\">Please login</a><br>\n";
addcomment_FIXED.inc.php: echo "<h2>Invalid recipe ID</h2>\n";
addcomment_FIXED.inc.php: echo "<h2>Sorry, comment is required and must be less than 5000 characters</h2>\n";
addcomment_FIXED.inc.php: echo "<h2>Database error. Please try again later.</h2>\n";
addcomment_FIXED.inc.php: echo "<h2>Database error. Please try again later.</h2>\n";
addcomment_FIXED.inc.php: echo "<h2>Sorry, that recipe does not exist</h2>\n";
addcomment_FIXED.inc.php: echo "<h2>Sorry, we could not post your comment at this time</h2>\n";
addcomment_FIXED.inc.php: echo "<h2>Sorry, there was a problem posting your comment</h2>\n";
addcomment_FIXED.inc.php: echo "<h2>Comment posted successfully!</h2>\n";
addcomment_FIXED.inc.php:echo "<a href=\"index.php?content=showrecipe&id=" . htmlspecialchars($recipeid, ENT_QUOTES, 'UTF-8') . "\">
Return to recipe</a>\n";
addrecipe.inc.php: echo "<h2>Sorry, each recipe must have a poster</h2>\n";
addrecipe.inc.php: echo "<h2>Recipe posted</h2>\n";
addrecipe.inc.php: echo "<h2>Sorry, there was a problem posting your recipe</h2>\n";
addrecipe_FIXED.inc.php: echo "<h2>Sorry, you must be logged in to post recipes</h2><br>\n";
addrecipe_FIXED.inc.php: echo "<a href=\"index.php?content=login\">Please login</a><br>\n";
addrecipe_FIXED.inc.php: echo "<a href=\"index.php\">Return to Home</a>\n";
addrecipe_FIXED.inc.php: echo "<h2>Sorry, recipe title is required and must be less than 200 characters</h2>\n";
addrecipe_FIXED.inc.php: echo "<h2>Sorry, recipe description is required and must be less than 500 characters</h2>\n";
addrecipe_FIXED.inc.php: echo "<h2>Sorry, ingredients field is required and must be less than 5000 characters</h2>\n";
addrecipe_FIXED.inc.php: echo "<h2>Sorry, directions field is required and must be less than 5000 characters</h2>\n";
addrecipe_FIXED.inc.php: echo "<h2>Sorry, we could not post your recipe to the database at this time</h2>\n";
addrecipe_FIXED.inc.php: echo "<h2>Sorry, there was a problem posting your recipe</h2>\n";
addrecipe_FIXED.inc.php: echo "<h2>Recipe posted successfully!</h2>\n";
addrecipe_FIXED.inc.php: echo "<a href=\"index.php\">Return to Home</a>\n";
adduser.inc.php: echo "<h2>Sorry, we can not process your request at this time, please try again later</h2>\n";
```

➤ File Inclusion Vulnerabilities:

```
PS C:\xampp\htdocs\reciphp> findstr /S /I "include(" *.php
index.php:<?php include("header.inc.php"); ?>
index.php:<?php include("nav.inc.php"); ?>
index.php: include("main.inc.php");
index.php: include($nextpage);
index.php:<?php include("news.inc.php"); ?>
index.php:<?php include("footer.inc.php"); ?>
index_FIXED.php:include("header.inc.php");
index_FIXED.php: include("main.inc.php");
index_FIXED.php: include($nextpage);
index_FIXED.php: <?php include("nav.inc.php"); ?>
index_FIXED.php: <?php include("news.inc.php"); ?>
index_FIXED.php:<?php include("footer.inc.php"); ?>
PS C:\xampp\htdocs\reciphp> |
```

7. Remediation and Secure Coding Practices:

➤ SQL Injection Prevention:

- Use prepared statements
- Avoid direct concatenation of user input in SQL queries

➤ XSS Prevention:

- Sanitize output using html special chars()
- Validate user input before processing

➤ Secure Credential Management:

- Remove hard-coded credentials
- Store sensitive data using environment variables

➤ **File Inclusion Protection:**

- Avoid dynamic file inclusion using user input
- Use whitelisting for allowed files

8. Recommendation Best Practices:

- Follow secure coding standards defined by OWASP
- Regularly review source code
- Keep PHP and dependencies updated
- Conduct security testing before deployment

9. Conclusion:

The secure coding review of the ReciPHP application revealed multiple security vulnerabilities, including SQL Injection, Cross-Site Scripting, hard-coded credentials, and file inclusion issues. Applying secure coding practices such as prepared statements, input sanitization, and secure configuration management significantly improves application security and reduces the risk of exploitation.

< ----- THE END ----- >